

Task 2: Nmap Scripting Engine (NSE) Integration

This report documents the use of the Nmap Scripting Engine (NSE) to extend scans beyond basic port discovery. NSE uses Lua scripts organised into categories. Each section below details the script used, what it does, the result observed, and the security implications.

2.1 Default Scripts — `nmap -sC`

The `-sC` flag runs all scripts in the "default" category — a curated set of safe, informative scripts that activate automatically based on detected services.

Commands

```
nmap -sC 127.0.0.1
nmap -sC -sV 127.0.0.1
```



```
Session Actions Edit View Help
root@kali: ~
root@kali:~# nmap -sC 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-07 22:24 SAST
Nmap scan report for localhost [127.0.0.1]
Host is up (0.0000020s latency).
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds

root@kali:~# nmap -sC -sV 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-07 22:24 SAST
Nmap scan report for localhost [127.0.0.1]
Host is up (0.000013s latency).
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 0.37 seconds

root@kali:~# nmap --script vuln 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-07 22:25 SAST
Nmap scan report for localhost [127.0.0.1]
Host is up (0.0000000s latency).
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 10.25 seconds

root@kali:~#
```

Figure 1: Default script scan (`-sC`) and combined default + version scan (`-sC -sV`)

What these scripts do: The default category includes scripts such as `ssh-hostkey` (enumerates SSH host keys and their fingerprints), `http-title` (grabs HTTP page titles), `ssl-cert` (reads SSL certificate details and expiry), and `smtp-command`s (lists SMTP server capabilities). Scripts are automatically selected based on what services are detected.

Result: On localhost with no open ports, no scripts produced output. On scanme.nmap.org (referenced in Task 1, Figure 8), the `ssh-hostkey` script automatically triggered, returning all four SSH host key fingerprints.

Security implication: Default scripts collect significant intelligence with minimal effort. SSH key fingerprints can be used to identify specific server instances over time or detect key changes that might indicate a man-in-the-middle attack.

2.2 Vulnerability Detection — `--script vuln`

The vuln category runs scripts that probe for specific known CVEs and security weaknesses in detected services.

Commands

```
nmap --script vuln 127.0.0.1
```



```
Session Actions Edit View Help
root@kali: ~
root@kali:~# nmap -sT 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-07 22:26 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000000s latency).
All 1400 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds

root@kali:~# nmap -sT 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-07 22:26 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000013s latency).
All 1400 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

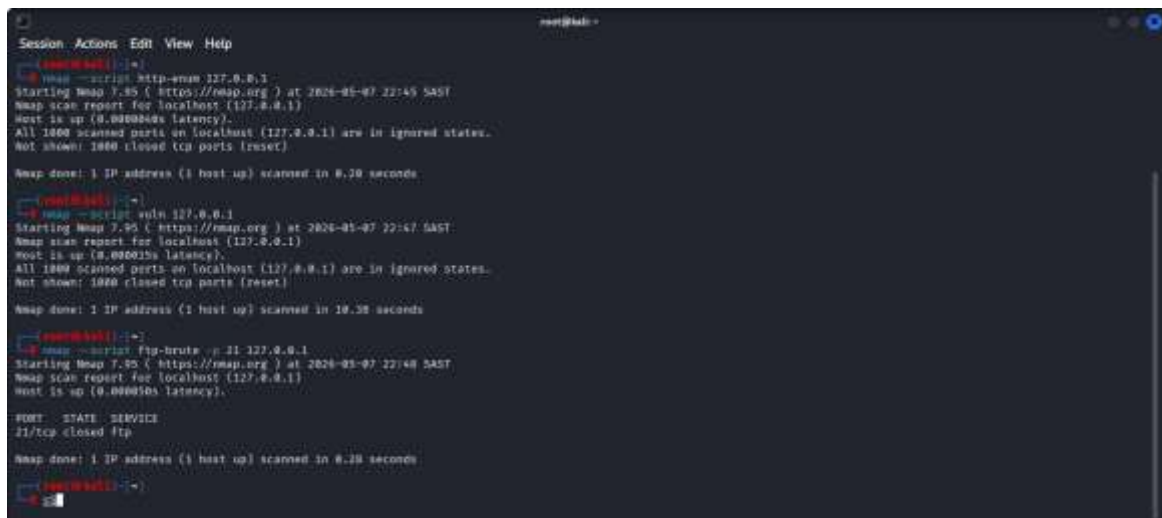
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds

root@kali:~# nmap --script vuln 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-07 22:25 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000000s latency).
All 1400 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 10.25 seconds

root@kali:~#
```

Figure 2: Vuln script run — 10.25 seconds on localhost



```
Session Actions Edit View Help
root@kali: ~
root@kali:~# nmap --script http-enum 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-07 22:45 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000000s latency).
All 1400 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 0.20 seconds

root@kali:~# nmap --script vuln 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-07 22:47 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000013s latency).
All 1400 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 10.38 seconds

root@kali:~# nmap --script ftp-brute -p 21 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-07 22:48 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000050s latency).

PORT      STATE SERVICE
21/tcp    closed ftp

Nmap done: 1 IP address (1 host up) scanned in 0.28 seconds

root@kali:~#
```

Figure 3: Additional vuln run alongside http-enum and ftp-brute

```
Session Actions Edit View Help
root@kali:~#
root@kali:~# nmap --script smb-vuln-ms17-010 -p 445 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2024-05-07 22:45 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000000s latency).

PORT      STATE SERVICE
445/tcp    closed microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds

root@kali:~# nmap --script http-enum 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2024-05-07 22:45 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000000s latency).
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 0.20 seconds

root@kali:~# nmap --script ssl0 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2024-05-07 22:47 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000020s latency).
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 10.28 seconds

root@kali:~#
```

Figure 4: Further vuln and http-enum execution results

What the script does: The vuln category includes scripts such as http-shellshock (tests for Bash shellshock), smb-vuln-ms17-010 (EternalBlue), ssl-poodle, http-csrf, http-dombased-xss, and dozens more. Each sends crafted probes and analyses responses for known vulnerability signatures.

Result: No vulnerabilities found; all 1,000 ports were closed on localhost. The scan took 10.25 to 10.38 seconds because the engine still runs all applicable checks even against closed ports. On a live server, this would return specific CVE IDs.

Security implication: Running vuln scripts against production systems without written authorisation is illegal. In authorised penetration tests, this is one of the fastest routes to identifying unpatched, high-severity vulnerabilities that automated patching may have missed.

2.3 FTP Backdoor Check — ftp-vsftpd-backdoor

This script checks whether a target FTP server is the trojanised vsftpd 2.3.4 build, which contains a deliberately introduced backdoor that opens a root shell on port 6200.

Commands

```
nmap --script ftp-vsftpd-backdoor 127.0.0.1
nmap --script ftp-anon -p 127.0.0.1      # error - wrong syntax
nmap --script ftp-anon -p 21 127.0.0.1   # corrected
```

```
Session Actions Edit View Help
root@kali: ~
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 10.25 seconds

root@kali: ~#
root@kali: ~# nmap --script ftp-vsftpd-backdoor 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2020-05-07 22:13:55 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000000s latency).
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 0.12 seconds

root@kali: ~#
root@kali: ~# nmap --script ftp-anon -p 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2020-05-07 22:14:08 SAST
Error 2467: Your port specifications are illegal. Example of proper form: "-100,200-1024,7:3000-4000,0:60000-"
QUITTING!

root@kali: ~#
root@kali: ~# nmap --script ftp-anon -p 21 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2020-05-07 22:14:08 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000001s latency).

PORT      STATE SERVICE
21/tcp    closed ftp

Nmap done: 1 IP address (1 host up) scanned in 0.20 seconds

root@kali: ~#
root@kali: ~#
```

Figure 5: ftp-vsftpd-backdoor and ftp-anon results — port 21 closed on localhost

What the script does: Connects to port 21 and sends a crafted login string with " :) " in the username. If the backdoor is active, port 6200 opens and accepts a root shell connection. The ftp-anon companion script checks whether anonymous FTP login is permitted.

Result: Port 21/tcp was closed on localhost, so neither script found anything to test. A syntax error occurred on the first ftp-anon attempt (missing port number after -p). The correct syntax nmap --script ftp-anon -p 21 127.0.0.1 was then used successfully.

Challenge encountered: The error "Your port specifications are illegal" appeared when the port number was omitted. This taught the importance of reading Nmap error messages carefully and correcting syntax before assuming a script is broken.

Security implication: The vsftpd 2.3.4 backdoor carries a CVSSv3 score of 9.8 (Critical). Any unpatched instance is trivially exploitable with full root access in seconds, as demonstrated in Task 3 using Metasploit.

2.4 FTP Anonymous Login — ftp-anon

```
Session Actions Edit View Help
root@kali: ~
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 0.20 seconds

root@kali: ~#
root@kali: ~# nmap --script ftp-anon -p 21 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2020-05-07 22:14:08 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000001s latency).

PORT      STATE SERVICE
21/tcp    closed ftp

Nmap done: 1 IP address (1 host up) scanned in 0.20 seconds

root@kali: ~#
root@kali: ~# nmap --script ssh-nmap-algos -p 22 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2020-05-07 22:14:30 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000000s latency).

PORT      STATE SERVICE
22/tcp    closed ssh

Nmap done: 1 IP address (1 host up) scanned in 0.15 seconds

root@kali: ~#
root@kali: ~# nmap --script ftp-nmap -p 80 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2020-05-07 22:14:44 SAST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000007s latency).

PORT      STATE SERVICE
80/tcp    closed http

Nmap done: 1 IP address (1 host up) scanned in 0.14 seconds

root@kali: ~#
```

Figure 6: ftp-anon on port 21, ssh2-enum-algos on port 22, http-enum on port 80

What the script does: Attempts to log in to the FTP server as "anonymous" with a blank password. Anonymous FTP is a common misconfiguration that allows unauthenticated users to read or upload files.

Result: Port 21/tcp closed. No FTP service on localhost means the script has nothing to test.

Security implication: Anonymous FTP access, if enabled, can expose sensitive files or allow attackers to upload malicious content. The ftp-vsftpd-backdoor scan in Task 3 against 192.168.56.101 confirmed that anonymous FTP login was allowed on the Metasploitable target (FTP code 230 returned).

2.5 SSH Algorithm Enumeration — ssh2-enum-algos

This script queries an SSH server and lists all supported cryptographic algorithms for key exchange, host keys, encryption, and MACs.

Command

```
nmap --script ssh2-enum-algos -p 22 127.0.0.1
```

Result (see Figure 6): Port 22/tcp was closed on localhost. No algorithms were returned. On the Metasploitable target (Task 3), OpenSSH 4.7p1 was discovered running on port 22, which supports outdated algorithms including SSLv2 ciphers.

Security implication: Weak SSH algorithms such as diffie-hellman-group1-sha1 and RC4-based ciphers are cryptographically broken. Modern SSH hardening should enforce only curve25519-sha256 for key exchange and chacha20-poly1305 or aes256-gcm for encryption.

2.6 HTTP Directory Enumeration — http-enum

The http-enum script brute-forces common web paths against an HTTP server to find hidden directories, admin panels, and exposed files.

Commands

```
nmap --script http-enum 127.0.0.1  
nmap --script http-enum -p 80 127.0.0.1
```

Result (see Figure 6): Port 80/tcp was closed on localhost. No enumeration was possible. On the Metasploitable target, nmap -A -T4 confirmed Apache httpd 2.2.8 running on port 80 with the page title "Metasploitable2 — Linux", making it a valid target for http-enum in a live engagement.

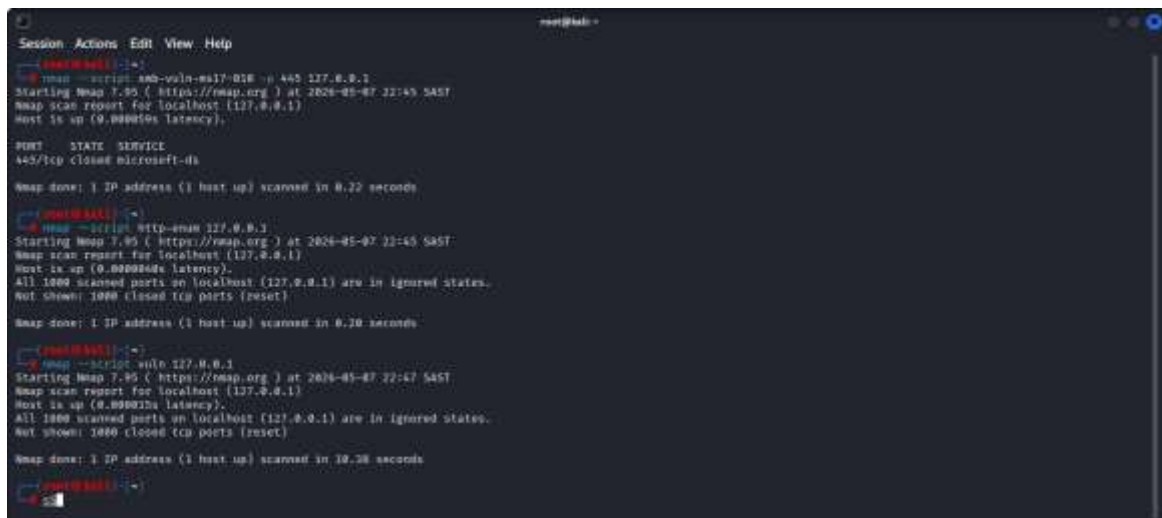
Security implication: Default web server installations often ship with accessible management interfaces (phpMyAdmin, Tomcat Manager, DVWA). http-enum maps these before an attacker does, enabling proactive remediation.

2.7 SMB Vulnerability Check — smb-vuln-ms17-010

This script detects the EternalBlue vulnerability, which allows remote unauthenticated code execution against Windows SMBv1 and was weaponised in the 2017 WannaCry ransomware attack.

Command

```
nmap --script smb-vuln-ms17-010 -p 445 127.0.0.1
```



```
root@kali: ~#
root@kali: ~# nmap --script smb-vuln-ms17-010 -p 445 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2024-05-07 22:45 SAST
Nmap scan report for localhost [127.0.0.1]
Host is up (0.000050s latency).

PORT      STATE SERVICE
445/tcp    closed microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds

root@kali: ~# nmap --script http-enum 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2024-05-07 22:45 SAST
Nmap scan report for localhost [127.0.0.1]
Host is up (0.000004s latency).
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 0.20 seconds

root@kali: ~# nmap --script vuln 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2024-05-07 22:47 SAST
Nmap scan report for localhost [127.0.0.1]
Host is up (0.000030s latency).
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 10.38 seconds

root@kali: ~#
```

Figure 7: smb-vuln-ms17-010 on port 445 and additional vuln/http-enum runs

What the script does: Sends a crafted SMBv1 negotiation packet to port 445 and analyses the server response to determine if it is vulnerable to MS17-010.

Result: Port 445/tcp closed on localhost. In the Task 1 subnet scan, host 10.0.2.2 had port 445 open with SMB message signing enabled and required; a mitigating control against certain relay attacks, though it does not protect against EternalBlue directly.

Security implication: EternalBlue remains one of the most dangerous vulnerabilities ever disclosed. Unpatched Windows systems with SMBv1 enabled and port 445 reachable are fully compromisable. All Windows hosts should have MS17-010 patched and SMBv1 disabled.

2.8 NSE Against Metasploitable — ftp-vsftpd-backdoor (Live Target)

The ftp-vsftpd-backdoor NSE script was also run against the real Metasploitable target to validate what was found during the manual Nmap scan.

Command

```
nmap --script ftp-vsftpd-backdoor -p 21 192.168.56.101
```

```
root@kali:~# ./ftp-vsftpd-backdoor -p 21 192.168.56.101
Starting Nmap 7.85 ( https://nmap.org ) at 2024-05-06 18:43 SAST
Nmap scan report for 192.168.56.101
Host is up (0.0003s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
MAC Address: 08:00:27:1B:11:1C8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 34.33 seconds
root@kali:~#
```

Figure 8: ftp-vsftpd-backdoor script confirms port 21 open on 192.168.56.101

Result: Port 21/tcp confirmed open. The scan took 34.33 seconds because the script attempts to trigger and verify the backdoor, which involves waiting for port 6200 to respond. The MAC address confirms the target is an Oracle VirtualBox virtual NIC.

This result directly bridges Tasks 2 and 3: the NSE script identified the vulnerability, and Task 3 shows the full exploitation using Metasploit.